

Administrative Artifacts

AccessGaurd System

Security Policies | Incident Response | Monitoring Guidelines

Audit Checklist | Compliance Mapping

Security Policies

This list of policies ensure that administrator, users, and systems will interact with this AccessGaurd in an efficient manner under certain policies. All individuals who have access to AccessGaurd must follow these rules. Non-Compliance will result in the revocation of access as well as disciplinary action.

User Access Policy

Policy ID: SEC-RUL-001

Version: 1.0

Owner: IT Security manager

Effective: When System is deployed

Purpose: Set of standards which permits the action of reviewing, granting, modifying and revoking the access to this system in order to protect the data of the organization and maintain access in the least-privilege way.

Scope: Any individual such as third-party vendors, employees, service accounts and contractor which have the access to the AccessGaurd System.

Statement of Polices:

- Each of the access requests have to be sent throughout the approved IT ticketing structure as well as require the approval of the documented manager before provisioning.
- The Access can only be granted on a need-to-know bases. Not one individual has permitted to have more access than is required in order to fulfill their designated responsibilities.
- The access of privileged must require the approval from both the CISO and the IT security Manager, as well as a justification of business documentation.
- The rights of access need to be reviewed semi-annually by the direct manager of the users with help by the IT Security Team. The accounts which have not been used for over 60 days need to be disabled.
- It is imperative for each individual to have their own private, unique and transferable credentials. No account shall be shared.
- If remote access is necessary, it will be permitted only while using the approved VPN gateway with the MFA enforced.
- Documented owners are imperative for service accounts and should be quarterly reviewed.
- The grants which are given on a temporary basis need to contain a set expiry date and shall not be extended without the approval of a higher-up.

Administrative Access Policy

Policy ID: SEC-RUL-002

Version: 1.0

Owner: CISO

Effective: When System is deployed

Purpose:

Secure and govern the usage of each administrative account in order to prevent the system changes which are unauthorized, ensure complete auditability of each administrative action, prevent the risk from inside threats.

Scope:

Each individual who is assigned the role of system administrator or similar with higher privileged such as security configuration, database administrator, and infrastructure management.

Policy Statements:

- Accounts of administrators shall not be users for day-to-day tasks that do not require administration.
- Each session shall be recorded using the capture tooling and retain these logs for at least 180 days.
- Each of the account passwords shall be at minimum of 16 characters, rotate every 60 days, and meet the requirement of complexity.
- Each of the emergency access accounts shall be sealed in a physically secure storage unit, have access through a dual-person authentication.
- Outside of approval change windows, administrative access to the systems of production is prohibited.
- All of the access to the administration shall be approved and formally requested, then logged in the system with a proper ticket number.
- Each administrator shall do the full security training with their qualified roles.

System Usage policy

Policy ID: SEC-RUL-003

Version: 1.0

Owner: IT Security Manager

Effective: When System is deployed

Purpose:

Sets the prohibited and accepted use of Accessgaurd in order to protect the assets of the organization and ensures the complete compliance and maintenance of the integrity of the system.

Acceptable Usage:

- These systems shall only be used for purposes which are authorized by businesses and relate directly to the responsibility of the job.
- Users shall only access the data which is necessary and covered under their explicit authorization.
- Policy violations, security incidents, or even suspicious behavior shall be reported directly to the SOC using the designated reporting channel.
(soc@accessGaurd.internal)

Prohibited Usage:

- Copying, modifying, or accessing data which is beyond the scope of the given permission.
- Attempting to disable, circumvent, or test the controls of security without the proper authorization from CISO.
- Downloading software's which are unapproved and will be connected to the AccesGaurd system.
- Storing confidential or restricted data on one's personal device from an unencrypted media site or unapproved cloud service.
- Using the resources of the system for cryptocurrency mining, personal gain, or any related activity for business operations.

Incident Response Procedures

This part defines the proper and official procedures for classifying, detecting, containing, escalating and resolving the incidents of security in the AccessGaurd system.

1. Incident Classification

Priority	Definition	Examples	Response SLA
P1 — CRITICAL	Complete outage of service of active breach	Confirmed data exfiltration; Ransomware; unavailability of full system	Response needed immediately, 24/7; mobilization of all IR resources
P2 — HIGH	Major security event or significant degradation of system	Partial outage, credential compromise; targeted phishing success	Within the first 30 minutes; escalate issue to CISO
P3 — MEDIUM	Activity that is suspicious and would require investigation	Repeated failed authentication; detection pf policy violation; anomalous patterns	Within 4 hours; normal hours of business
P4 — LOW	Minimal-risk or informational events which need tracking.	Minor misconfiguration; outdated software flag; user policy reminder	Within 5 business days

2. Incident Response Phases

#	Phase	Key Activities	Responsible Party	Exit Criteria
1	Detection & Triage	SIEM fires alert; alert reviewed by analyst; severity assigned (P1–P4); incident ticket created	SOC Analyst (Tier 1)	Severity assigned; ticket looked at within 15 min of alert
2	Escalation	P1/P2 incidents escalated to CISO and IR Lead; legal and stakeholders notified per communication matrix	IR Lead / CISO	All necessary parties notified within 30 minutes
3	Containment	Accounts which are affected are disabled; segment of networks isolated; revocation of tokens; malicious targets blocked at firewall/WAF	IR Team + SysAdmin	Threat contained; no additional lateral movement noticed
4	Eradication & Fixes	Identification of root cause and documented; removal of malware; config or patches fixes applied; vulnerability closed	Security Engineering	Removal of evidence of threat; no continuation in 24 hr monitoring
5	Recovery & Review	Controlled sequence of service restoration; monitoring increased for 72 hours; Post-Incident Review (PIR) completed	IR Lead + Management	PIR report delivered in 5 business days; lessons fulfilled

3. Communication Matrix

Priority	Immediate Notification	Within 1 Hour	External / Regulatory
P1	SOC Analyst → IR Lead (immediate) → CISO (15 min)	PR; Legal; Executive Team; as required	Notify regulators per apprehended breach laws within first 72 hr
P2	SOC Analyst → IR Lead (within 15 min) → CISO (25 min)	Department head; affected system owners;	Legal review necessary prior to external disclosure
P3	SOC Analyst → IR Lead (within 1.5 hours)	Manager of affected user(s) within first 4 hours	None unless data is involved — consult Legal
P4	Ticket started; assigned to proper owner	No further escalation required unless not resolved after 5 days	None

Procedures for Evidence preservations

1. Do not reboot, modify or power the affected system without the proper authorization from the actual IR Lead.
2. Capture the affected system of memory dump prior to the containment of the actions which are taken by the forensic analysis.
3. Properly preserve all of the data from the log within the affected window of time, placing a hold of legal authority within the SIEM.
4. Write down the custody chain using each of the pieces as evidence, including digital artifacts.
5. Store the images of forensic within the encrypted, protected media within he locations that are physically secure and only viewed by the Legal and IR Team.
6. Do not discuss any of the details with someone outside of the incident response team unless given permission by the CISO.

Logging and Monitoring Guidelines

This area will establish the set standards for the monitoring, security, retention, security and alert responses inside the AccessGaurd system. Repeated logging is required to detect threats and compliance auditing.

1. Log Retention Standards

Log Category	Hot Retention	Cold Retention	Integrity Check	Storage Location
Authorization & Authentication	90 days	2 years	SHA-256 daily	SIEM + Encrypted Archive
Administrative Actions	90 days	3 years	SHA-256 daily	SIEM + Encrypted Archive
Application & API Logs	30 days	1 year	SHA-256 weekly	SIEM
Network & Firewall Logs	30 days	1 year	SHA-256 weekly	SIEM
Database Query Logs	14 days	1 year	SHA-256 weekly	SIEM + DB Archive
Security Incident Records	Permanent	Permanent	Monthly audit	SIEM + Legal Hold
VPN Access Logs	90 days	2 years	SHA-256 daily	SIEM + Encrypted Archive

Security Validation and Audit Checklist

This formal checklist shall be used for the quarterly audits of internal security as well as for the pre-deployment gate of validation that is mandatory. Each of the selected items must be verified independently by a qualified reviewer. The results of the document need to be written with the date and name of the reviewer as well as any failed actions.

Audit Field	Value			
Auditor Name				
Audit Date				
Audit Scope				
System Version				

1. Access Control

Check Item	Pass	Fail	N/A	Notes
All of the active user accounts have a viewable corresponding active HR record in the files.	☐	☐	☐	
None of the user accounts have permissions that go beyond their assigned RBAC roles	☐	☐	☐	
All of the privileged account grants have the proper documented dual approval within the main file	☐	☐	☐	
Previous departed employee accounts were disabled within the imperative SLA of 1-hour	☐	☐	☐	
Accounts inactive for 60+ days have been reviewed and disabled or justified	☐	☐	☐	
Service or Shared accounts have the documented owners and were reviewed within the first 90 days	☐	☐	☐	
MFA is properly enrolled and active for 100% of the user accounts	☐	☐	☐	

Temporary access grants are not going beyond their proper approved expiry dates	☐	☐	☐	
Quarterly access review has been completed for all of the privileged roles	☐	☐	☐	
Password policy (complexity, length, history, max age) is enforced via IdP config	☐	☐	☐	

Compliance Mapping Overview

This section goes over the AccessGaurd security controls that corresponds to the main requirements in the major compliance frameworks. Used for gap analysis.

AccessGaurd Control	Description	NIST 800-53	ISO 27001:2022	SOC 2 TSC	Status
RBAC Enforcement	Role-based access; the less privileged are enforced in each access request.	AC-2, AC-3, AC-6	A.9.2, A.9.4	CC6.1, CC6.3	Active
MFA Enforcement	Multi-factor authentication imperative for all accounts	IA-2, IA-5	A.9.4.2	CC6.1	Active
SSO / IdP Integration	Centralized identity via OIDC/SAML; no local authentication	IA-2, IA-8	A.9.4	CC6.1	Active
Immutable Audit Logging	Tamper-proof logs of each of the security events	AU-2, AU-3, AU-9	A.12.4	CC7.2	Active
Log Retention	Main 90 days; cold up to 3+ years	AU-11	A.12.4.1	CC7.2	Active
Plan for Incident Response	5-phase's IR with SLAs, PIR and escalation matrix	IR-1 - IR-8	A.16	CC7.3, CC7.4	Active

Encryption at Rest	Encrypted volumes, AES-256 for database PII;	SC-28, SC-12	A.10.1	CC6.7	Active
Encryption in Transit	TLS 1.3 enforced on all endpoints	SC-8	A.10.1, A.13.2	CC6.7	Active
Key Management	Annual rotation KMS for all cryptographic keys;	SC-12, SC-13	A.10.1.2	CC6.7	Active
Vulnerability Management	Critical patches within 30 days; Monthly scans;	RA-5, SI-2	A.12.6	CC7.1	Active
Change Management	Approved change process; All changes via ticketed	CM-3, CM-5	A.12.1.2	CC8.1	Active